

Controls and compliance checklist

To complete the controls assessment checklist, refer to the information provided in the [scope, goals, and risk assessment report](#). For more details about each control, including the type and purpose, refer to the [control categories](#) document.

Then, select “yes” or “no” to answer the question: *Does Botium Toys currently have this control in place?*

Controls assessment checklist

Yes	No	Control
☐	☒	Least Privilege
☐	☒	Disaster recovery plans
☐	☒	Password policies
☐	☒	Separation of duties
☒	☐	Firewall
☐	☒	Intrusion detection system (IDS)
☐	☒	Backups
☒	☐	Antivirus software
☐	☒	Manual monitoring, maintenance, and intervention for legacy systems
☐	☒	Encryption
☐	☒	Password management system
☒	☐	Locks (offices, storefront, warehouse)
☒	☐	Closed-circuit television (CCTV) surveillance

- ☒ ☐ Fire detection/prevention (fire alarm, sprinkler system, etc.)

To complete the compliance checklist, refer to the information provided in the [scope, goals, and risk assessment report](#). For more details about each compliance regulation, review the [controls, frameworks, and compliance](#) reading.

Then, select “yes” or “no” to answer the question: *Does Botium Toys currently adhere to this compliance best practice?*

Compliance checklist

Payment Card Industry Data Security Standard (PCI DSS)

Yes	No	Best practice
☐	☒	Only authorized users have access to customers’ credit card information.
☐	☒	Credit card information is stored, accepted, processed, and transmitted internally, in a secure environment.
☐	☒	Implement data encryption procedures to better secure credit card transaction touchpoints and data.
☐	☒	Adopt secure password management policies.

General Data Protection Regulation (GDPR)

Yes	No	Best practice
☐	☒	E.U. customers’ data is kept private/secured.
☒	☐	There is a plan in place to notify E.U. customers within 72 hours if their data is compromised/there is a breach.
☐	☒	Ensure data is properly classified and inventoried.

- | | | |
|-------------------------------------|--------------------------|---|
| ☒ | ☐ | Enforce privacy policies, procedures, and processes to properly document and maintain data. |
|-------------------------------------|--------------------------|---|

System and Organizations Controls (SOC type 1, SOC type 2)

Yes	No	Best practice
☐	☒	User access policies are established.
☐	☒	Sensitive data (PII/SPII) is confidential/private.
☒	☐	Data integrity ensures the data is consistent, complete, accurate, and has been validated.
☐	☒	Data is available to individuals authorized to access it.

This section is *optional* and can be used to provide a summary of recommendations to the IT manager regarding which controls and/or compliance best practices Botium Toys needs to implement, based on the risk posed if not implemented in a timely manner.

Recommendations (optional): In this section, provide recommendations, related to controls and/or compliance needs, that your IT manager could communicate to stakeholders to reduce risks to assets and improve Botium Toys' security posture.

Internal Audit Report - Summary Of Recommendations

To: IT Manager, Botium Toys

From: Michael Hanna, Internal Auditor

Date: 09/03/2025

Subject: Recommendations on Security Controls and Compliance Best Practices

1.Executive Summary

The internal audit of Botium Toys revealed several missing security controls and gaps in compliance with industry standards, including PCI DSS and SOC frameworks. These deficiencies increase the risk of data breaches, fraud, and regulatory non-compliance. Immediate corrective action is required to safeguard customer information, ensure compliance, and protect business continuity.

2.Key Findings and Risks

Controls Needing Attention

- **Least Privilege Not Enforced**
 - **Risk:** Users may have excessive access rights beyond their job functions, creating unnecessary exposure to sensitive data.
- **No Separation of Duties (SoD)**
 - **Risk:** Critical business and IT processes can be completed by one individual, increasing the risk of fraud or errors going undetected.
- **No Disaster Recovery Plan**
 - **Risk:** In the event of a major system outage, data loss, or cyberattack, Botium Toys lacks a tested plan to resume operations, leading to prolonged downtime and financial loss.

- **Weak or Missing Password Policies**
 - **Risk:** Users may use weak, reused, or default passwords, increasing vulnerability to credential theft.
- **No intrusion Detection system (IDS)**
 - **Risk:** Suspicious or malicious network activity may go undetected, delaying incident response.
- **No Regular Backups**
 - **Risk:** Data could be permanently lost or unrecoverable in the event of ransomware or hardware failure.
- **Manual Monitoring of Legacy Systems**
 - **Risk:** reliance on manual oversight increases the chance of human error, delayed response, overlooked systems anomalies.
- **No Centralized Password Management Systems**
 - **Risk:** Employees may store or share credentials insecurely, increasing the risk of unauthorized access.
- **No Encryption of Sensitive Data**
 - **Risk:** Customer Credit card information and PII are stored and Transmitted in plaintext, making it vulnerable to theft.

Compliance Gaps

Payment Card Industry Data Security Standard (PCI DSS)

- Only authorized users should have access to customers' credit card information (gap in current practice).
- Credit card information should be stored, accepted, processed, and transmitted internally in a secure environment.

- Encryption procedures must be implemented at transaction touchpoints and for stored data.
- Password management policies must align with PCI DSS best practices.

General Data Protection Regulation (GDPR)

- E.U. customers' personal data must be kept private and secured.
- Data must be classified and inventoried to ensure appropriate handling and protection.

System and Organization Controls (SOC 1 & SOC 2)

- User access policies are not fully established.
- Confidentiality of sensitive data (PII/SPII) is not fully ensured.
- Data availability for authorized individuals is not consistently guaranteed.

3. Recommendations

Control Recommendations

1. **Implement Least Privilege:** Restrict access rights to the minimum required for each role.
2. **Develop a Disaster Recovery Plan:** Create, document, and test procedures for disaster and outage recovery.
3. **Strengthen Password Policies:** Require strong, complex passwords with expiration periods and prohibit reuse.

4. **Enforce Separation of Duties:** Divide responsibilities across roles to reduce fraud and error risks.
5. **Deploy an Intrusion Detection System (IDS):** Monitor and alert on suspicious activity in real time.
6. **Establish Reliable Backups:** Automate and regularly test backup systems to ensure recovery capability.
7. **Automate Monitoring of Legacy Systems:** Reduce reliance on manual checks and implement modern monitoring tools.
8. **Encrypt Sensitive Data:** Apply encryption for data at rest and in transit.
9. **Adopt a Password Management System:** Provide a secure platform for password storage, rotation, and sharing.

Compliance Recommendations

PCI DSS

- Enforce strict access control for credit card information.
- Ensure secure processing, storage, and transmission of cardholder data.
- Encrypt data at all transaction points and while stored.
- Adopt secure password management aligned with PCI DSS requirements.

GDPR

- Implement privacy measures for E.U. customer data.
- Classify and inventory all data to ensure proper security controls are applied.

SOC 1 & SOC 2

- Formalize user access policies.
- Strengthen confidentiality protections for PII/SPII.
- Improve systems to ensure availability for authorized users.

4. Risk of Non-Implementation

If corrective action is not taken:

- **Regulatory:** Non-compliance with PCI DSS, GDPR, and SOC requirements may result in fines and loss of business contracts.
- **Financial:** Data breaches could lead to fraud, chargebacks, and recovery costs.
- **Reputational:** Loss of customer trust could directly impact sales and brand value.
- **Operational:** Unplanned outages or cyber incidents could halt business operations.

5. Conclusion

Botium Toys must prioritize implementation of both the security controls and compliance measures outlined above. Addressing these gaps will significantly reduce cyber risks, improve resilience, and ensure compliance with industry standards.